Detection 01: ICMP Flood — Network Denial of Service (T1498)

October 26, 2026 · Chris Giamalis

A single-source ICMP echo flood from the attacker host is detected end to end and escalated to a level 12 Wazuh alert mapped to MITRE ATT&CK T1498, using a Suricata rate threshold that feeds a custom Wazuh escalation rule.

Executive summary

An ICMP echo flood was launched from the attacker host (Kali, MFF #1) against a victim on the attack-range VLAN (MFF #2). Suricata, monitoring a mirror of the attacker's switch port, collapsed the flood into a single alert using a rate threshold, and that alert traversed the Suricata-to-Wazuh pipeline to the manager. A custom Wazuh rule (ID 100700) matched the alert, escalated it to level 12, and tagged it MITRE ATT&CK T1498, Network Denial of Service. The detection was validated end to end: running the flood reliably produces the level 12 alert in the dashboard. This is the lab's first complete, ATT&CK-mapped detection and the template for the remaining nine.

Environment

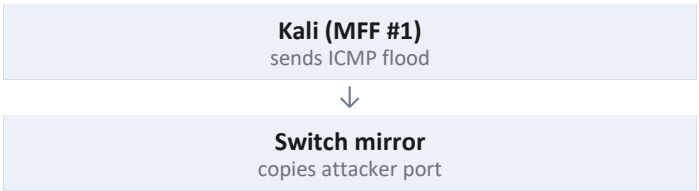
The lab is a segmented SOC environment built on three mini-form-factor hosts behind UniFi networking, split into isolated VLANs. This detection exercises the attack range (VLAN 20) and the SOC segment (VLAN 30).

Role	Host	Segment	Function in this detection
Attacker	MFF #1, Kali	VLAN 20 (10.20.20.0/24)	Source of the ICMP flood
Victim	MFF #2	VLAN 20 (10.20.20.0/24)	Flood target
Sensor	MFF #3, Suricata LXC	VLAN 30 (10.30.30.21)	Inspects mirrored traffic, raises the Suricata alert
SIEM	MFF #3, Wazuh manager	VLAN 30 (10.30.30.20)	Decodes, correlates, escalates, and surfaces the alert

The SOC segment has one-way visibility into the attack range; the attack range cannot initiate into the SOC segment. Suricata does not sit in the traffic path. It observes a copy of the attacker's switch port delivered by a switch port mirror, so the detection is passive and out-of-band.

Detection pipeline

The alert is the product of a seven-stage pipeline that carries the flood from the attacker's wire to a dashboard row. The design principle: the sensor measures the rate and emits one verdict, and every stage after it reasons over that single event rather than the raw packet stream.





Detection pipeline · 7 stages, attacker to dashboard

The critical handoff is eve.json, where network detection becomes SIEM data. Before it, Suricata is inspecting packets; after it, every event is just another JSON log entering the Wazuh pipeline, where the built-in JSON decoder parses it and the ruleset evaluates it.

The attack

The attack is a single-source ICMP echo flood, generated from Kali on MFF #1:

```
sudo hping3 --icmp --flood <MFF2-IP>
```

`--icmp` sends ICMP echo requests (type 8, the same packets a normal ping uses). `--flood` sends them as fast as the interface allows, with no inter-packet delay and no waiting for replies. The result is a high-rate stream of echo requests aimed at one target, intended to consume the victim's bandwidth and processing. It is denial of service by volume, from one host, which is the attack this detection is scoped to catch.

The detection

The detection is split across the two engines by design: Suricata does the rate counting and emits one summarizing alert, and Wazuh escalates that single alert. This keeps the log pipeline from having to ingest one event per flood packet.

Suricata rule (custom, in `local.rules`). The `threshold` keyword turns a per-packet signature into a rate detector:

```
alert icmp any any -> $HOME_NET any (msg:"LAB DoS - ICMP flood to
  target"; itype:8; threshold:type both, track by_dst, count 50,
  seconds 5; classtype:attempted-dos; sid:1000020; rev:2;)
```

`itype:8` matches echo requests. `track by_dst` counts per destination, so the rule measures how much is arriving at one target. `count 50, seconds 5` fires when 50 matching packets reach that target within a 5-second window. `type both` emits one alert when the threshold is crossed and at most once per interval, which collapses the flood into a single event. The `any any -> $HOME_NET` address form is required here

because both attacker and victim are inside `10.20.20.0/24`; the usual external-to-internal form would match nothing.

Wazuh rule (custom, in `local_rules.xml`). A single-event rule that recognizes the Suricata flood alert and escalates it:

```
<group name="suricata,dos,custom,">
  <rule id="100700" level="12">
    <if_sid>86601</if_sid>
    <field name="alert.signature">LAB DoS - ICMP flood</field>
    <description>DoS detected: ICMP flood against target
      ($(alert.signature))</description>
    <mitre>
      <id>T1498</id>
    </mitre>
  </rule>
</group>
```

`if_sid 86601` chains to the built-in rule that fires on any Suricata alert-type event. The `field` match on `alert.signature` singles out this flood and nothing else, promotes it from the built-in level 3 to level 12, and attaches the ATT&CK tag.

Resulting alert. Running the flood produces, in the Wazuh dashboard: rule 100700, level 12, “DoS detected: ICMP flood against target (LAB DoS - ICMP flood to target),” from the suricata-sensor agent.

The investigation

Confirming the alert as a true positive required separating it from two unrelated event streams that appeared during testing. Each was identified by three fields: the rule ID, the agent or source, and the event type.

The first was rule 510, “Host-based anomaly detection event (rootcheck).” It looked like the detection firing but was a scheduled rootkit and file-integrity scan running on the sensor's own host, unrelated to network traffic. The rule ID (rootcheck, not Suricata) and the source (the sensor host, not mirrored traffic) identified it as coincidence.

The second was a flood of rule 86601 events, “SURICATA STREAM ESTABLISHED packet out of window.” These are stream-reassembly events, an artifact of monitoring through a lossy port mirror: the mirror copy arrives late, out of order, or incomplete, so Suricata's TCP reassembler repeatedly sees packets outside the expected window. Their volume tracked the observation method under load, not an attack.

With those ruled out, the true positive is unambiguous: rule 100700, level 12, firing only when the ICMP flood crosses the Suricata threshold, carrying the destination of the flood in its description. In a production SOC the triage from here would be to confirm the source and destination, check whether the target is degraded, and either rate-limit or block the source at the gateway. In this lab the source is the known attacker host, which closes the investigation.

ATT&CK mapping

Technique: T1498, Network Denial of Service (Tactic: Impact). The technique covers degrading or blocking the availability of a target by exhausting network resources, typically through flooding. An ICMP echo flood is a textbook volumetric instance: it consumes bandwidth and processing to deny service, which is exactly what T1498 describes.

The sub-technique T1498.001 (Direct Network Flood) is the more precise label, since the flood is sent straight from the source to the target rather than reflected or amplified through a third party. The rule is tagged at the parent T1498 level; narrowing to .001 is a reasonable refinement for a later revision.

Limitations and next steps

This detection has a precisely bounded scope, and naming it is part of the analysis. It fires only on a flood of ICMP echo requests (type 8), to a single destination, at a rate above the tuned threshold. It does not fire on a SYN flood, a UDP flood, an application-layer HTTP flood, a low-and-slow attack, or an ICMP flood using a different message type. Each of those is a separate detection with a different matching mechanism.

Two honest constraints:

- **This is DoS, not DDoS.** The lab has a single attacker, so the flood comes from one source. Tracking by destination means the same rule would still catch a multi-source flood, but the lab cannot currently generate that case.
- **The threshold is tuned to a lossy sensor, not to theory.** The count was lowered from 500 to 50 per 5 seconds because mirror packet loss and the USB 2.0 capture NIC's throughput ceiling meant the higher value never crossed. The before (500, never fired) and after (50, fires reliably) is recorded as a tuning result: the correct threshold is the one that matches what the observation path actually delivers, not the raw packet rate sent.

Next detections, in priority order, each exercising a mechanism this one does not: a SYN flood (TCP protocol-state matching on `flags:S`), an HTTP flood against DVWA (behavioral request-rate analysis in web logs), and a Slowloris slow-rate attack (connection-state monitoring, documented as a sensor blind spot). Together with this rule, those span the distinct detection strategies for denial of service across layers 3 through 7.